

Compte rendu du TP2.2 Chapitre2 cyber sécurité

Analyse et correction des vulnérabilités

Introduction

Ce TP vise à transformer la détection passive de vulnérabilités en une stratégie de remédiation active pour renforcer la sécurité des cibles. L'objectif est de durcir les systèmes en appliquant des mesures concrètes suite aux alertes identifiées.

Partie 1 : Analyse des vulnérabilités critiques

1. Vulnérabilités Windows

La vulnérabilité **MS17-010 (EternalBlue)** exploite une faille critique du protocole **SMBv1** permettant l'exécution de code à distance via le port 445. Le risque est majeur : une prise de contrôle totale de la machine et une propagation rapide de ransomwares au sein du réseau. L'exploitation se fait par l'envoi de paquets malveillants spécifiquement forgés pour saturer la mémoire du service. Une capture d'écran de **Nessus** avant correction confirme ici la présence de la faille.



- La vulnérabilité SMB Signing not required indique que les communications SMB ne sont pas signées numériquement, facilitant ainsi les attaques de type Man-in-the-Middle. Le risque principal réside dans

l'interception et la modification du trafic, permettant à un attaquant sur le même réseau d'usurper l'identité du serveur. Cette faille est exploitable par des outils de relaying qui capturent les sessions authentifiées pour obtenir un accès non autorisé.

Vulnerabilities 18

MEDIUM SMB Signing not required

Description

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks the SMB server.

Solution

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

See Also

<http://www.nessus.org/u?df39b8b3>
<http://technet.microsoft.com/en-us/library/cc731957.aspx>
<http://www.nessus.org/u?774b80723>
<https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html>
<http://www.nessus.org/u?7a2aac1a3>

2. Vulnérabilités Linux

Vulnerabilities 24

LOW ICMP Timestamp Request Remote Date Disclosure

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Output

```
The difference between the local and remote clocks is -296 seconds.
```

To see debug logs, please visit individual host

Port ▲	Hosts
--------	-------

Plugin Details

Severity:	Low
ID:	10114
Version:	1.56
Type:	remote
Family:	General
Published:	August 2008
Modified:	October 2008

VPR Key Drivers

Threat Recency:	No records
Threat Intensity:	Very Low
Exploit Code Maturity:	Partial
Age of Vuln:	730 days +
Product Coverage:	Very Low
CVSSV3 Impact Score:	1.0

Partie 2 & 3 : Correction et Remédiation

1. Actions sur Windows

- **Commande utilisée pour le pare-feu :** `netsh advfirewall set allprofiles state on`

2. Actions sur Linux

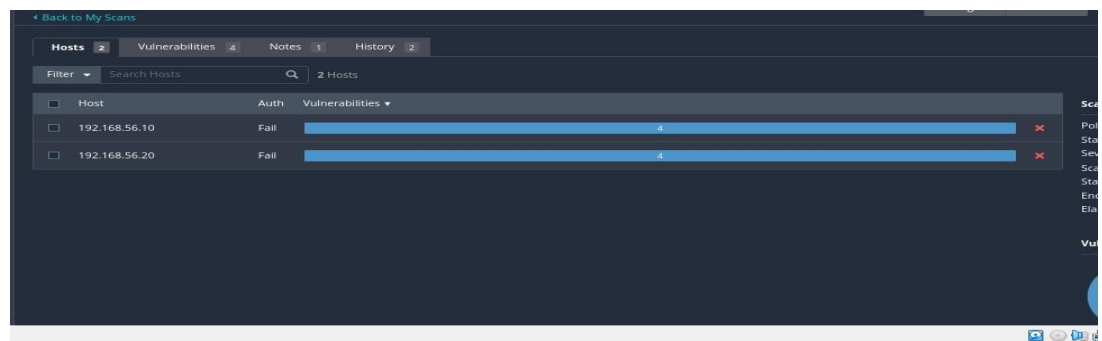
- **Mises à jour :** `sudo apt update && sudo apt upgrade -y`
- **Configuration pare-feu :** `sudo ufw enable`

Partie 4 : Re-scan Nessus et Comparaison

Comparaison des résultats

Résultat final (Scan de vérification)

- **Commentaire :** après mise à jour des paquets et activation des pare-feu, on constate qu'il y'a plus aucune vulnérabilité visible.
- **Capture d'écran (Scan Nessus Après correction) :**



Conclusion

Le durcissement des systèmes, par la mise à jour des logiciels et la désactivation des services superflus, réduit efficacement la surface d'attaque. L'activation des pare-feu complète cette protection en limitant les points d'entrée exploitables par des acteurs malveillants.